THREAT ADVISORY

PHP2Shell

Two Critical Flaws Prompt Emergency Updates

PHP has released emergency fixes for two critical vulnerabilities that can allow unauthenticated remote code execution. Known as **PHP2Shell**, the flaws affect the underlying PHP runtime. Cloudflare reports exploitation attempts, while administrators are urged to apply the security updates immediately.

Sources: **PHP Security Team · Cloudflare** · 21 Oct 2026
CVE-2026-109618 · CVE-2026-109619 · PHP Runtime

Memori CTI

THREAT ADVISORY / 21 OCTOBER 2026

PHP releases emergency security updates

PHP has released emergency updates for **CVE-2026-109618** and **CVE-2026-109619**, two critical vulnerabilities known as **PHP2Shell**. Successful exploitation can allow an unauthenticated attacker to execute code with the privileges of the PHP web worker.

The PHP team urges administrators to update affected installations immediately. Apache with mod_php is considered the highest-risk configuration because demonstrated attacks can reach vulnerable code before the requested application script starts running. Fixed versions are listed on page 6.

9.2

CRITICAL

CVSS v4.0

Both CVEs

TWO REQUEST-LIFECYCLE FAILURES

CVE-2026-109618

Request cleanup processes internal data that was not fully initialized before an out-of-memory interruption.

CVE-2026-109619

A later request accesses internal state that still points to memory freed after an earlier request.

Both vulnerabilities carry a **CVSS v4.0 score of 9.2 - Critical.** Their published vectors require no authentication or user interaction, but identify high attack complexity and additional conditions for exploitation.

How the vulnerabilities work

CVE-2026-109618

Memory corruption during cleanup

PHP uses longjmp() to interrupt processing when an out-of-memory condition occurs. If this happens before internal data has been fully initialized, request cleanup can process invalid memory and cause memory corruption.

Crafted multipart requests can consume considerably more memory inside PHP than their transmitted size suggests. This allows an attacker to exhaust the PHP memory limit while remaining within apparent request-size limits.

PHP confirms unauthenticated remote code execution against mod_php with default input and memory limits. Exploit reliability varies with the PHP build, extensions and server environment.

CVE-2026-109619

Stale state between requests

Some PHP operations store references to request-owned memory in worker-level state. If an error interrupts the operation before those references are reset, they can remain after the memory has been freed.

A later request handled by the same worker may access those stale references before normal initialization clears them. An attacker who can control the relevant memory layout may turn this use-after-free condition into code execution.

Confirmed paths involve fatal-error backtraces and session upload-progress handling. The exact requirements depend on the PHP version, server configuration and application behavior.

EXPOSURE

Affected environments and confirmed impact

Calif traces an affected path back to **PHP 5.4.0** and reports successful exploitation against applications including WordPress, Drupal, Joomla, MediaWiki, Roundcube and phpMyAdmin. The applications provide examples of exposure; the vulnerabilities are in the underlying PHP runtime.

The evidence for Apache mod_php and PHP-FPM differs between the two CVEs:

VULNERABILITY	APACHE mod_php	PHP-FPM
CVE-2026-109618	RCE demonstrated, including a path before application code executes.	The advisory identifies susceptibility through source analysis, but does not report a completed FPM exploit for this CVE.
CVE-2026-109619	RCE confirmed through fatal-backtrace and session lifecycle paths.	Session lifecycle RCE confirmed through a suitable application operation after successful request startup.

PHP-FPM terminates a worker when request startup fails, preventing the same startup-failure sequence used against mod_php. That behavior does not cover errors reached after application execution has started.

Wiz also demonstrated remote disclosure of PHP process memory, which can contain passwords, authentication tokens and API keys. Code execution is therefore not the only potential impact.

DISCLOSURE & ATTACK ACTIVITY

Disclosure timeline and observed attacks

The PHP Foundation says signs of the OOM problem were identified in 2024. Work on a fix stalled because of compatibility concerns, limited resources and the lack of a demonstrated exploitation path. Reports from Calif, OpenAI and Wiz in 2026 established the practical impact and made remediation a priority.

---

20 OCT On **20 October**, the CVE identifiers circulated publicly alongside an incorrect severity score of 10.0. PHP brought forward its announcement and moved the planned release from **22 October to 21 October**. A prematurely published demonstration video disclosed additional limited details.

OBSERVED ATTACK TRAFFIC

Cloudflare reports observing attack traffic against its customers, including changes to payloads intended to bypass its protections. The company deployed WAF protections before public disclosure and continued updating them as attack techniques changed.

This confirms observed exploitation attempts. Cloudflare's report does not establish that those attempts successfully compromised the targeted servers.

REMEDIATION

Fixed versions and update verification

PHP BRANCH	FIXED RELEASE
8.2	**8.2.35**
8.3	**8.3.36**
8.4	**8.4.27**
8.5	**8.5.12**

Distribution and LTS vendors received patches in advance. Administrators using vendor packages should check the applicable security advisory and package release.

PHP 8.1 and older no longer receive normal upstream security updates. Some vendors provide backported fixes, and PHP has supplied minimal source backports for 7.4, 8.0 and 8.1.

After updating, administrators should restart the affected PHP workers and verify that the web service is using the patched runtime. Checking php -v alone is insufficient because the command-line installation may differ from the version serving web requests. Each relevant instance, container or server should be checked.

For distribution packages, verification should include the vendor's backport status and package revision. A backported fix may be present without the upstream version number shown in the table.

Updating a CMS, theme or plugin alone does not apply the PHP runtime fix.

Temporary measures and their limits

The complete PHP update is the only full remediation. Temporary measures reduce exposure to particular attack paths.

OUT-OF-MEMORY HANDLING

```
memory_limit=-1
```

For the OOM issue, PHP describes administratively enforcing memory_limit=-1 as a partial measure. It removes the predictable PHP memory-limit trigger, but underlying allocation failures can still reach vulnerable behavior. Removing the cap also increases memory-exhaustion risk.

Request limits

Keep post_max_size conservative and enforce decoded request-size limits at the frontend. Bound multipart parts, headers, nesting and input counts. Block multipart traffic where the application does not need it.

TEMPORARY CONTROLS

Controls for specific stale-state paths

SESSION UPLOAD PROGRESS

```
session.upload_progress.enabled=0
```

Disable session.upload_progress.enabled and restart every worker to block the demonstrated early session paths.

PHP 8.5 BACKTRACES

```
fatal_error_backtraces=0
```

Disable fatal_error_backtraces and restart every worker to remove the confirmed fatal-backtrace producer.

Per-request configuration

Review invalid or deprecated INI settings that generate diagnostics before normal request initialization. Suppressing displayed errors does not prevent the underlying access to stale state.

These settings do not cover every variant. WAF protections can provide additional coverage during patch deployment, but they do not replace the runtime update. Cloudflare combines request and response signals because request inspection alone may not reliably identify an exploit.

HUNTING REFERENCE

Indicators & hunting clues

Wiz identifies several behavioral clues that can support an investigation:

OBSERVABLE	RELEVANCE
Unusual multipart requests followed by memory-limit errors	May indicate attempts to trigger vulnerable memory-handling paths.
Repeated HTTP 500 responses after unusual requests	May accompany failures during exploitation attempts.
Unexpectedly large or malformed PHPSESSID **response cookies**	May relate to the demonstrated process-memory disclosure path.
Unexplained PHP worker exits or frequent replacement	May accompany crashes or repeated triggering attempts.

These observations require context. Multipart traffic, HTTP 500 responses and worker restarts also occur during legitimate activity. Their sequence and timing are more useful than an isolated match, and none alone proves successful compromise.

PHP cautions that missing error messages do not demonstrate safety. Logging settings may exclude relevant diagnostics, and some failures occur before a message can be written.

The sources reviewed for this advisory do not provide a validated, campaign-specific list of malicious IP addresses, domains or payload hashes. This section therefore presents behavioral investigation clues without asserting threat-actor attribution.

Stay vigilant. **Follow Memori CTI for more threat intel.**